

Xây dựng nền tảng chia sẻ video trực tuyến với hệ thống chuyển mã HLS tự động trên kiến trúc Serverless Container và Event-Driven

Báo cáo tiến độ tuần 4 - 29/08/2026 đến 04/09/2026

Đề tài	Xây dựng nền tảng chia sẻ video trực tuyến với hệ thống chuyển mã HLS tự động trên kiến trúc Serverless Container và Event-Driven
Sinh viên thực hiện	Đình Quốc Cường (523H0008) Võ Huỳnh Minh Đức (523H0014)
Giảng viên hướng dẫn	ThS. Mai Văn Mạnh
Tuần báo cáo	Tuần 4 (29/08/2026 - 04/09/2026)
Tỷ lệ hoàn thành tuần	100%

1. Đối chiếu kế hoạch và kết quả

Tuần 4 hoàn thiện module xác thực người dùng trên nền API đã dựng ở tuần 3: đăng ký và đăng nhập bằng JSON Web Token, middleware bảo vệ endpoint, cùng luồng quên và khôi phục mật khẩu qua email. Đây cũng là tuần đầu tiên có kiểm thử tự động.

Kế hoạch	Kết quả	Trạng thái
Phát triển module xác thực JWT (đăng ký, đăng nhập).	Đã hoàn thành tại backend/src/services/authService.js. Mật khẩu băm bằng bcrypt qua hook pre('save') của Mongoose nên không đường nào lưu được mật khẩu thô. Trường mật khẩu đặt select: false để không lọt ra trong các truy vấn thông thường.	Hoàn thành
Xây dựng middleware bảo vệ các endpoint cần đăng nhập.	Đã có hai middleware tại backend/src/middleware/auth.js: auth bắt buộc đăng nhập, và optionalAuth cho các trang vừa phục vụ khách vãng lai vừa phục vụ người đã đăng nhập (ví dụ trang xem video công khai).	Hoàn thành
Xây dựng tính năng quên và khôi phục mật khẩu qua email.	Đã hoàn thành. Token đặt lại được sinh ngẫu nhiên, băm SHA-256 trước khi lưu và có hiệu lực 15 phút. Lưu bản băm là có chủ đích: nếu cơ sở dữ liệu bị lộ, token trong đó không dùng lại được. Email gửi qua SMTP tại backend/src/services/emailService.js.	Hoàn thành
Bổ sung kiểm thử tự động cho tầng xác thực.	Đã viết 31 kiểm thử trên hai bộ: authService (17) và authMiddleware (14), phủ các nhánh đăng ký trùng, đăng nhập sai, token bị giả mạo chữ ký, token hết hạn và token của người dùng đã bị xoá. Toàn bộ đều đạt.	Hoàn thành
Chống dò mật khẩu ở các endpoint xác thực.	Đã giới hạn 10 lần thử trong 15 phút cho nhóm endpoint xác thực (backend/src/middleware/rateLimiter.js), đủ chặn dò mật khẩu tự động mà không ảnh hưởng người dùng thật.	Hoàn thành

2. Kết quả kỹ thuật chính

- Luồng xác thực đầy đủ: đăng ký → đăng nhập → cấp JWT → middleware xác thực → đổi mật khẩu, cùng luồng khôi phục mật khẩu qua email.

- Mật khẩu không bao giờ tồn tại ở dạng thô trong cơ sở dữ liệu: bcrypt băm tại hook pre-save, còn trường mật khẩu bị loại khỏi kết quả truy vấn mặc định.
- Token đặt lại mật khẩu lưu dưới dạng băm SHA-256 kèm hạn 15 phút — kẻ đọc được cơ sở dữ liệu vẫn không tái sử dụng được token.
- Middleware tách làm hai mức auth và optionalAuth, vì hệ thống có những trang cần biết người xem là ai nếu họ đã đăng nhập nhưng vẫn phải phục vụ được khách vắng lai.
- Bộ kiểm thử tự động đầu tiên của dự án: 31 kiểm thử cho tầng xác thực, chạy được mà không cần dựng máy chủ HTTP nhờ kiến trúc phân lớp từ tuần 3.
- Máy chủ kiểm tra biến môi trường bắt buộc ngay khi khởi động và từ chối chạy nếu thiếu khoá ký JWT, biến một lỗi nguy hiểm lúc chạy thành một lỗi lộ ra ngay lập tức.

3. Minh chứng và kết quả kiểm tra

Minh chứng	Nội dung
backend/src/services/authService.js	Đăng ký, đăng nhập, sinh JWT, quên và đặt lại mật khẩu, đổi mật khẩu.
backend/src/middleware/auth.js	Hai middleware auth và optionalAuth.
backend/src/services/emailService.js	Gửi email chứa liên kết đặt lại mật khẩu qua SMTP.
backend/src/models/User.js	Hook bcrypt pre-save, phương thức so khớp mật khẩu và sinh token đặt lại.
backend/src/middleware/rateLimiter.js	Giới hạn tần suất cho nhóm endpoint xác thực.
backend/tests/authService.test.js backend/tests/authMiddleware.test.js	31 kiểm thử tự động cho tầng xác thực.

Lệnh kiểm tra	Kết quả
npx jest tests/authService.test.js tests/authMiddleware.test.js	Tests: 31 passed, 31 total — 2 bộ kiểm thử đều đạt
curl -X POST /api/auth/register	HTTP 201, trả về JWT; phản hồi không chứa trường mật khẩu
curl -X POST /api/auth/login (sai mật khẩu)	HTTP 401, thông báo lỗi không tiết lộ tài khoản có tồn tại hay không
curl /api/auth/me (không kèm token)	HTTP 401 — middleware auth chặn đúng

4. Giới hạn và rủi ro hiện tại

- JWT không lưu trạng thái phía máy chủ nên chưa thu hồi được token trước hạn: đổi mật khẩu hiện cấp token mới nhưng token cũ vẫn còn hiệu lực tới khi hết hạn. Nhóm ghi nhận đây là hạn chế cần xử lý và sẽ bàn trong chương đánh giá.
- Kiểm thử ở tuần này dùng mock cho tầng model, nên chúng kiểm chứng logic nghiệp vụ chứ chưa kiểm chứng tương tác thật với cơ sở dữ liệu.
- Thông tin đăng nhập SMTP hiện đặt trong biến môi trường cục bộ; việc đưa vào kho bí mật có quản lý sẽ thực hiện ở giai đoạn dựng hạ tầng.
- Chưa có xác minh địa chỉ email khi đăng ký, nên một tài khoản có thể tạo bằng email không thuộc sở hữu người đăng ký.

5. Cam kết cho tuần tiếp theo

	Nội dung
1	Xây dựng cơ chế tải video trực tiếp lên Amazon S3 bằng Pre-signed PUT URL.
2	Kiểm chứng phía máy chủ định dạng và dung lượng tệp trước khi cấp URL tải lên.
3	Viết Chương 2 báo cáo đồ án (Cơ sở lý thuyết và khảo sát).